MacZine
THE MACTECH SOLUTIONS NEWSLETTER
ISSUE Nº 069 · NOVEMBER 2026 · MACTECHSOLUTIONSLLC.COM/MACZINE

NEWS · VULNERABILITY MANAGEMENT

CISA's Three-Day Patch Deadline Is Now the Rule, Not the Exception

Since June 11, 116 of 145 exploited flaws CISA listed carry a three-day federal deadline. What that means for a small contractor's patch policy.

BY MAXINE

READING TIME · 5 MIN

KEV · BOD-26-04 · PATCH-MANAGEMENT · NIST-800-171 · VULNERABILITY-MANAGEMENT

If your patch policy gives an actively exploited flaw on your firewall thirty days, it now allows ten times what the federal government allows itself for most of the flaws on CISA's list. That gap is new this year, it is measurable, and it widened again in the last two weeks.

When Issue 40 covered scanning cadence in September, Binding Operational Directive 26-04 was three months old and the question was how its tiers would play out. The Known Exploited Vulnerabilities catalog now answers that. We pulled CISA's catalog feed on October 28 and measured the gap between the date each entry was added and the federal due date CISA assigned it.

FIELD COPY
ISSUE Nº 069
KEV

116 of 145

KEV ENTRIES ADDED FROM JUNE 11 TO OCTOBER 28, 2026 WITH A THREE-DAY FEDERAL DUE DATE; THE OTHER 29 GOT FOURTEEN DAYS

226 of 245

KEV ENTRIES ADDED IN 2025 WITH A 21-DAY DUE DATE; NONE HAD THREE

Dec 7

180 DAYS AFTER BOD 26-04 ISSUED, WHEN ITS PHASE III REMEDIATION TIMELINES BIND CIVILIAN AGENCIES

What the catalog shows

In 2025, CISA added 245 entries. Of those, 226 carried a 21-day due date. Twelve carried seven days and seven carried one or two. None carried three.

From June 11, 2026, the first day an entry cited BOD 26-04, through October 28, CISA added 145 entries. Every one names the directive in its required action, and only two due dates appear: 116 entries got three days and 29 got fourteen. The 21-day deadline, the norm a year ago, has not been assigned since.

The last two weeks follow the pattern. Of 21 entries added from October 14 to October 28, fifteen carried three days. They include products small contractors run at the edge of their networks: a Palo Alto Networks PAN-OS code injection flaw (CVE-2026-0322) and a Cisco Secure Email Gateway path traversal (CVE-2026-76519), both added October 14; a BeyondTrust Remote Support authentication bypass (CVE-2026-102764) and a Fortinet path traversal across multiple products (CVE-2025-61624), both added October 16 with an October 19 deadline; and an Arista VeloCloud Orchestrator SQL injection (CVE-2026-114625), added October 23. The six that drew fourteen days included a VMware ESX logging flaw (CVE-2026-41709), added October 28 and due November 11.

Why three days, and why December 7 matters

BOD 26-04, issued June 10, revoked BOD 22-01 and BOD 19-02 and replaced a single deadline with four questions. Is the asset publicly exposed? Is the flaw in the KEV catalog? Can an adversary "automate all the steps necessary to exploit" it? Does exploitation give "partial control or total control" of the asset? CISA publishes answers to the last three for every CVE through its Vulnrichment program. The directive's background is direct about the reason: attackers' "use of AI may further narrow the time defenders have to react between patch release and possible exploitation."

The directive also runs in phases. Phase I, effective immediately, required agencies to update their vulnerability management policies. Phase III, "within 180 days of issuance," requires agencies to remediate "no later than the timelines set forth in Table 1." One hundred and eighty days from June 10 is Monday, December 7, 2026. CISA has

◆ HOW THESE NUMBERS WERE COUNTED

From CISA's catalog feed, version 2026.10.28, 1,762 entries. For each entry added since January 2025, we subtracted the dateAdded field from the dueDate field. Every entry added since June 11, 2026 names BOD 26-04 in its required action.

committed to reassess those timelines once per fiscal year and to study "whether technological or adversarial advances warrant further reductions in timelines." The direction of travel is stated in the document.

Thirty days was a patch policy. Against this catalog it is now a written promise to be late.

Where a contractor actually stands

The directive does not reach your systems by its own force. It applies to federal civilian executive branch systems, and it excludes national security systems and "certain systems operated by the Department of War." On contractors it is specific: "Unless directed by the governing procurement contract, this Directive does not apply to contractors, but FCEB agencies must review all contracts to determine what modifications are necessary to comply." A firm that runs systems on behalf of a civilian agency should expect that review to reach its contract, and should read any modification that cites BOD 26-04 closely.

For a defense contractor holding CUI, the binding text is still NIST SP 800-171 requirement 3.14.1, "identify, report, and correct system flaws in a timely manner," worth 5 points in the DoD Assessment Methodology. Its six assessment objectives ask whether you specified the time to identify, report and correct flaws, and whether you met those times. The number is yours to set. Issue 40 argued that the number has to survive the question of why a known, exploited flaw sat open; the catalog now supplies the comparison an assessor, a prime or an insurer is likely to reach for.

What to change in the patch policy this month

The practical response is a lane, not a rewrite. Most of what a small shop patches can stay on its monthly cycle. What changes is the treatment of one category: a KEV-listed flaw on an internet-facing system. That category gets its own written deadline, short enough to defend beside CISA's three days, with a named owner and a fallback of isolating the device when no fix exists. CISA's own required action for these entries says the same: apply the vendor's mitigations, or "discontinue use of the product if mitigations are unavailable."

Two inputs make the lane workable. First, a current list of what faces the internet: firewalls, VPN and remote access gateways, email gateways, remote support tools and anything published to the web. Second, a daily look at the catalog, which CISA publishes as a free feed and by email alert. Matching one against the other takes minutes once both exist.

The lane also needs paperwork, because a fast patch is still a change, and 3.4.3 expects every change to be tracked, reviewed, approved and logged, including the urgent ones. If you want an outside read on whether your 3.14.1 time frames would hold up beside this catalog, a readiness check is where to start. ◆